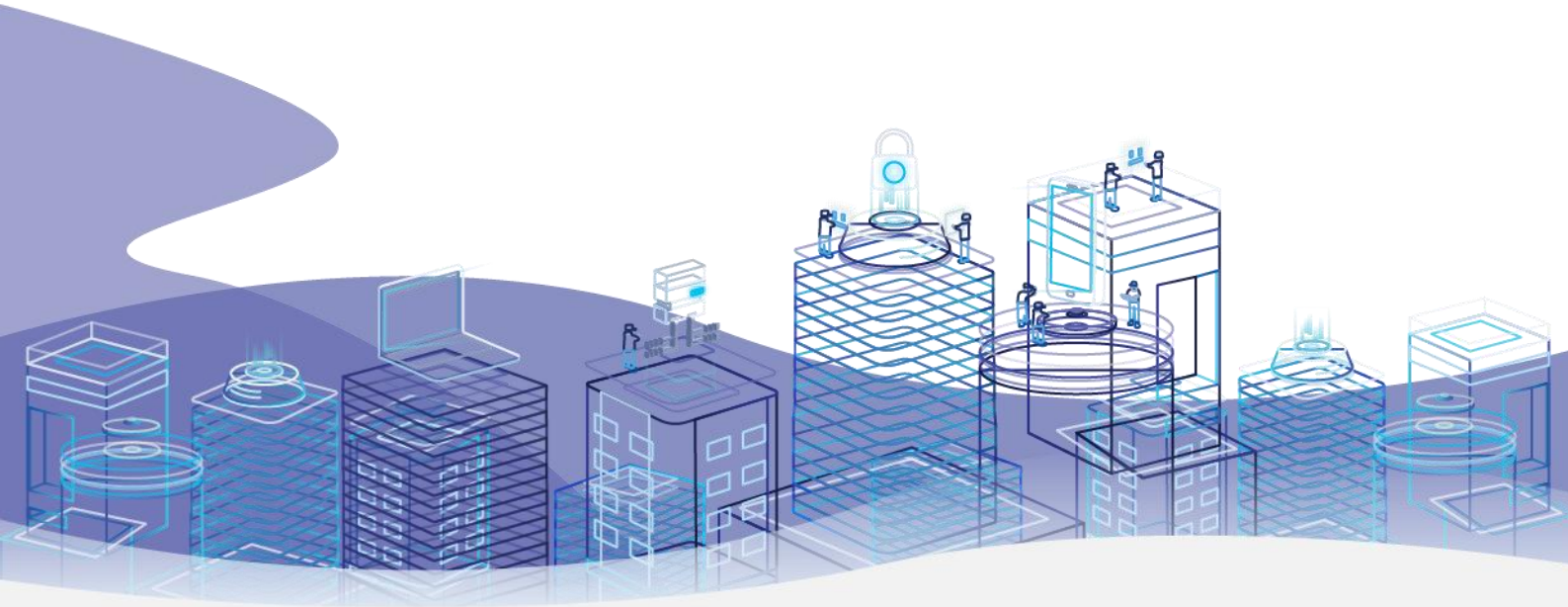
# Laporan Akhir
# Penetration Testing
# PT Vulnapp
# Aplikasi Vulnerable App



Klasifikasi Dokumen: **Rahasia**

# Daftar Isi

**1. Pendahuluan**

1.1 Ruang Lingkup Kegiatan

1.2 Periode Pekerjaan

1.3 Metodologi Pengujian

**2. Rangkuman Situasi**

**3. Hasil Penetration Testing**

3.1. SQL Injection - Login Bypass

3.2 SQL Injection - Error Based

3.3 Time Based Blind SQL Injection - Search Job

3.4 Sensitive Data Exposure

3.5 Unrestricted File Upload - Stored Arbitrary File

3.6 Insecure Direct Object Reference (IDOR) - Job Enumeration

3.7 Insecure Session Termination (Broken Access Control)

3.8 Weak Password Policy

3.9 Missing Security Headers (CSP & X-Frame-Options)

3.10 Information Disclosure (Nginx Version)

## Executive Summary

Pada tanggal 17 April 2026, aktivitas pengujian keamanan (Penetration Testing) telah dilaksanakan pada aplikasi *job portal* milik PT Vulnapp (https://jobportal.vulnapp.id). Pengujian ini bertujuan untuk mengidentifikasi celah keamanan yang berpotensi membahayakan data perusahaan dan pengguna. Secara keseluruhan, ditemukan 10 kerentanan keamanan, dengan 4 di antaranya berstatus Kritis (*Critical*) dan 2 berstatus Tinggi (*High*). Isu paling mendesak mencakup kelemahan logika autentikasi (Login Bypass) dan fungsi unggah dokumen (*Unrestricted File Upload*). Apabila celah ini dieksploitasi, penyerang dapat membobol data sensitif seluruh pendaftar kerja, mengambil alih sistem, dan merusak reputasi bisnis perusahaan. PT Vulnapp sangat direkomendasikan untuk segera memprioritaskan perbaikan (remediasi) pada celah *Critical*, khususnya dengan mengimplementasikan *Parameterized Queries* untuk database dan pembatasan tipe *file* yang ketat pada sisi server.

## 1. Pendahuluan

Laporan ini mendokumentasikan hasil kegiatan *Penetration Testing* (Pengujian Keamanan) yang dilaksanakan terhadap infrastruktur aplikasi *web* milik PT Vulnapp. Pengujian ini dilakukan secara komprehensif dari wilayah eksternal (mensimulasikan ancaman dari jaringan publik/internet) dengan menggunakan pendekatan Grey Box Testing. Melalui pendekatan ini, penguji diberikan informasi terbatas berupa akses kredensial tingkat pengguna oleh pihak pemilik bisnis. Simulasi ini bertujuan untuk mengukur ketahanan aplikasi, tidak hanya dari serangan pihak luar yang tidak dikenal (*anonymous attacker*), melainkan juga dari potensi ancaman internal (*insider threat*) atau eksploitasi yang dilakukan oleh pengguna terautentikasi.

Objektif utama dari pelaksanaan kegiatan ini adalah untuk mengidentifikasi, memvalidasi, dan mengevaluasi kerentanan teknis yang berpotensi membahayakan tiga pilar utama keamanan informasi (CIA Triad) perusahaan, yaitu:

> **Kerahasiaan (*Confidentiality*):** Mencegah akses, kebocoran, atau ekstraksi data sensitif (seperti data pribadi pencari kerja dan kredensial sistem) oleh pihak yang tidak memiliki otorisasi.
>
> **Integritas (*Integrity*):** Memastikan bahwa sistem dan basis data aman dari manipulasi, modifikasi, atau perusakan yang dilakukan secara ilegal.
>
> **Ketersediaan (*Availability*):** Menjamin bahwa infrastruktur dan layanan aplikasi tetap beroperasi secara optimal dan terhindar dari gangguan fungsionalitas akibat serangan siber.

Lebih lanjut, hasil dari pengujian ini disusun untuk memberikan wawasan teknis serta gambaran risiko bisnis bagi manajemen dan tim pengembang perangkat lunak PT Vulnapp. Laporan ini menyertakan bukti konsep eksploitasi (*Proof of Concept*) beserta rekomendasi perbaikan (*remediation*) yang strategis guna menutup celah keamanan dan meningkatkan postur pertahanan sistem secara keseluruhan.

## 1.1 Ruang Lingkup Kegiatan

Berdasarkan kesepakatan yang ada, objek pengujian terhadap aplikasi milik PT vulnapp, namun tidak terbatas pada objek tersebut, yaitu https://jobportal.vulnapp.id.

Adapun *checklist* pengujian dalam pekerjaan ini adalah sebagai berikut:

| No. | Checklist | Keterangan |
|---|---|---|
| 1. | Account takeover | Upaya untuk mengakses dan mengontrol akun pengguna tanpa izin, seringkali dengan mencuri kredensial. |
| 2. | Authentication bypass | Upaya untuk mengakses sistem atau aplikasi tanpa memerlukan proses otentikasi yang sah. |
| 3. | IDOR/Broken Access Control, sensitive actions by user | Upaya untuk mengakses objek atau sumber daya tanpa otorisasi yang benar. |
| 4. | Information disclosure / Sensitive data exposure | Upaya untuk mencari kelemahan yang memungkinkan akses atau pengungkapan data sensitif. |
| 5. | SQL injection | Upaya untuk menyisipkan kode SQL berbahaya ke dalam input aplikasi web. |
| 6. | Remote/Arbitrary code execution | Upaya untuk mencoba menjalankan kode arbitrer pada sistem target dari jarak jauh. |
| 7. | Timing or enumeration attacks that have a tangible risk to security or privacy | Upaya untuk mencoba mengumpulkan informasi sensitif dengan menganalisis pola atau waktu respon dari sistem target atau melalui enumerasi informasi secara berulang. |

## 1.2 Periode Pekerjaan

Aktivitas Penetration Testing ini dilaksanakan pada tanggal 17 April 2026 - 18 April 2026

## 1.3 Metodologi Pengujian

Pengujian dilakukan dengan *Helium Core Community* dan mengikuti metodologi keamanan standar. Tahapan yang dilakukan meliputi:

1. *Recon & Mapping*: Pemetaan struktur aplikasi dan pengumpulan informasi target.
2. *Parameter Analysis & Intercept*: Menganalisis parameter input yang dikirimkan klien ke server.
3. *Fuzzing & Exploitation*: Melakukan injeksi *payload* untuk menguji validasi aplikasi (seperti SQL Injection dan *File Upload*).
4. Reporting: Mendokumentasikan seluruh temuan beserta rekomendasi perbaikan secara sistematis.

## 2. Rangkuman Situasi

Berikut ini merupakan gambaran kerentanan yang berhasil ditemukan selama pengujian dilakukan:

| | Critical | High | Medium | Low |
|---|---|---|---|---|
| Vulnerability Found | 4 | 2 | 3 | 1 |
| Vulnerability Closed | 0 | 0 | 0 | 0 |

Secara spesifik, berikut ini merupakan daftar kerentanan yang ditemukan selama pengujian:

| No. | Nama Temuan | Tingkat Risiko | Status |
|---|---|---|---|
| 1. | SQL Injection - Login Bypass | Critical | OPEN |
| 2. | SQL Injection - Error Based | Critical | OPEN |
| 3. | Time-Based Blind SQL Injection - Search Job | Critical | OPEN |
| 4. | Sensitive Data Exposure | Critical | OPEN |
| 5. | Unrestricted File Upload - Stored Arbitrary File | High | OPEN |
| 6. | Insecure Direct Object Reference (IDOR) - Job Enumeration | High | OPEN |
| 7. | Insecure Session Termination (Broken Access Control) | Medium | OPEN |
| 8. | Weak Password Policy | Medium | OPEN |
| 9. | Missing Security Headers (CSP & X-Frame-Options) | Medium | OPEN |
| 10. | Information Disclosure (Nginx Version) | Low | OPEN |

# 3. Hasil Penetration Testing

## 3.1. SQL Injection - Login Bypass

### a. Deskripsi

Kerentanan ini memungkinkan penyerang untuk memanipulasi *query* SQL pada formulir login. Dengan menyisipkan karakter khusus, penyerang dapat memotong logika autentikasi dan masuk ke sistem tanpa kredensial yang valid.

### b. URL / Aplikasi

POST https://jobportal.vulnapp.id/login.php

### c. Status

**OPEN**

### d. Dampak

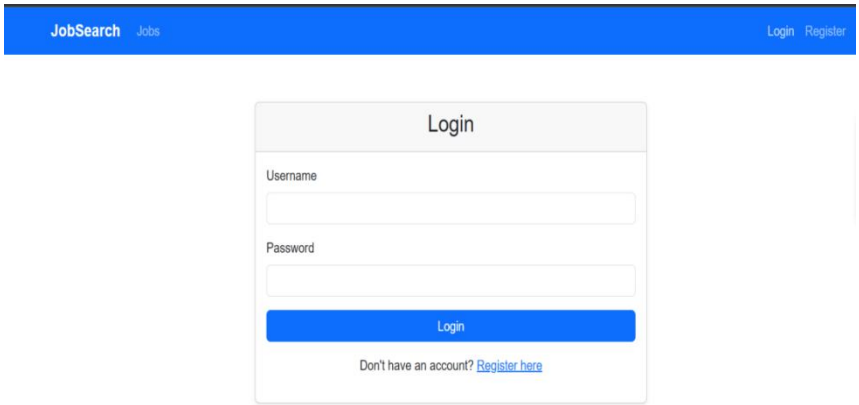
Penyerang dapat mengambil alih akun administrator, mengakses data sensitif seluruh pengguna (Confidentiality), dan berpotensi melakukan perubahan data yang tidak sah (Integrity), Secara bisnis, hal ini dapat mengakibatkan kebocoran Data Pribadi para pencari kerja yang berujung pada pelanggaran regulasi privasi data (seperti UU PDP), merusak reputasi dan kredibilitas PT Vulnapp di mata klien/mitra, serta berpoensi mendatangkan tuntutan hukum dan kerugian finansial yang masif.

### e. Nilai Risiko

| | |
|---|---|
| CVSS String | : **AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H** |
| CVSS Base Score | : **10** |
| Rating | : **Critical** |

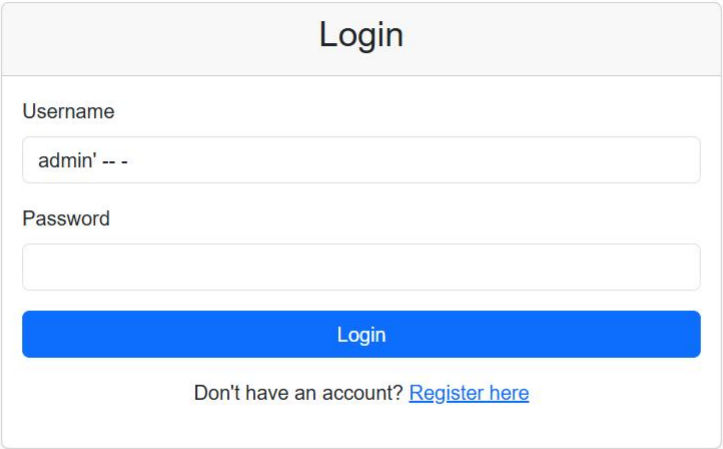
### f. Langkah-Langkah

1. Masuk ke halaman https://jobportal.vulnapp.id/login

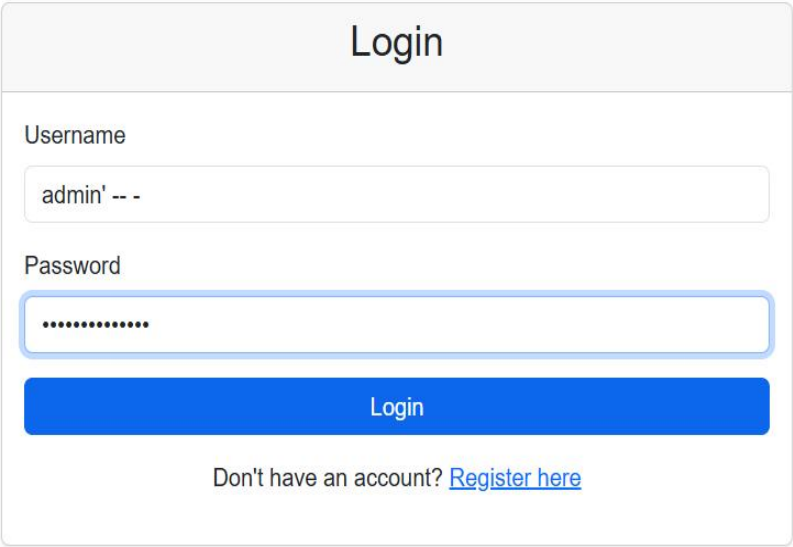


2. Pada kolom Username, masukan payload: “admin' -- -”

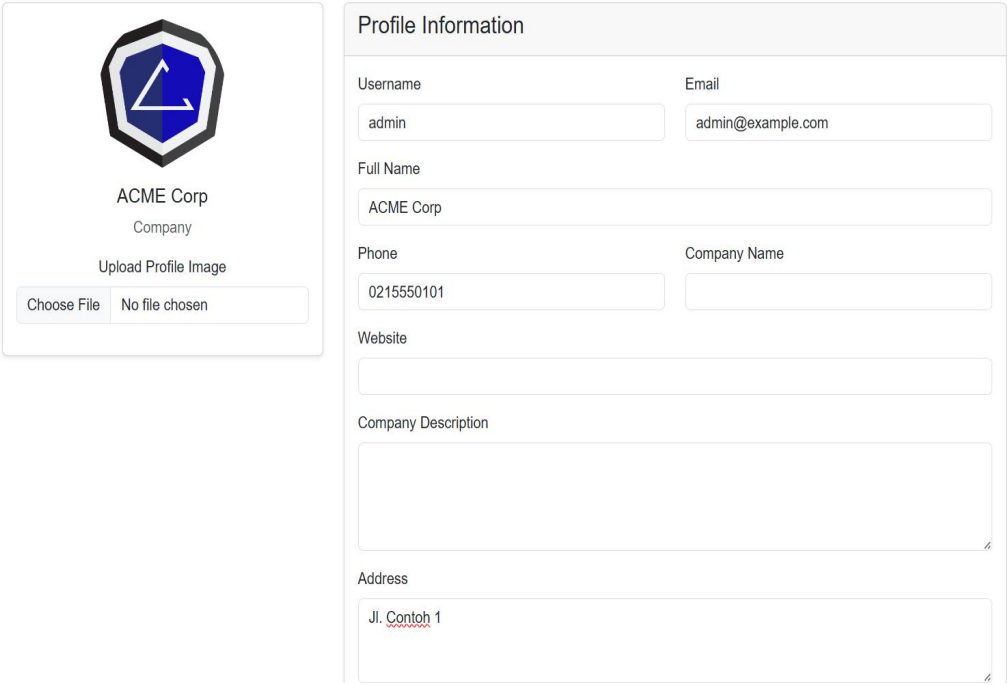
```
POST /login.php HTTP/1.1
Host: jobportal.vulnapp.id
Content-Type: application/x-www-form-urlencoded

username=admin' -- -&password=sembarang
```




3. Masukkan teks sembarang pada kolom **Password**.




4. Klik tombol Login
5. Sistem berhasil masuk ke dashboard admin tanpa perlu validasi password.




**g. Rekomendasi**

Gunakan *Parameterized Queries* atau *Prepared Statements* untuk semua interaksi database agar input pengguna tidak dieksekusi sebagai perintah SQL

**h. Referensi**

https://owasp.org/Top10/2021/A03_2021-Injection/index.html
https://cwe.mitre.org/data/definitions/89.html
http://projects.webappsec.org/w/page/13246963/SQL%20Injection

## 3.2. SQL Injection - Error Based

### a. Deskripsi

Aplikasi memberikan informasi teknis database secara langsung melalui pesan error saat menerima input yang tidak valid pada parameter login.

### b. URL / Aplikasi

POST https://jobportal.vulnapp.id/login.php

### c. Status

**OPEN**

### d. Dampak

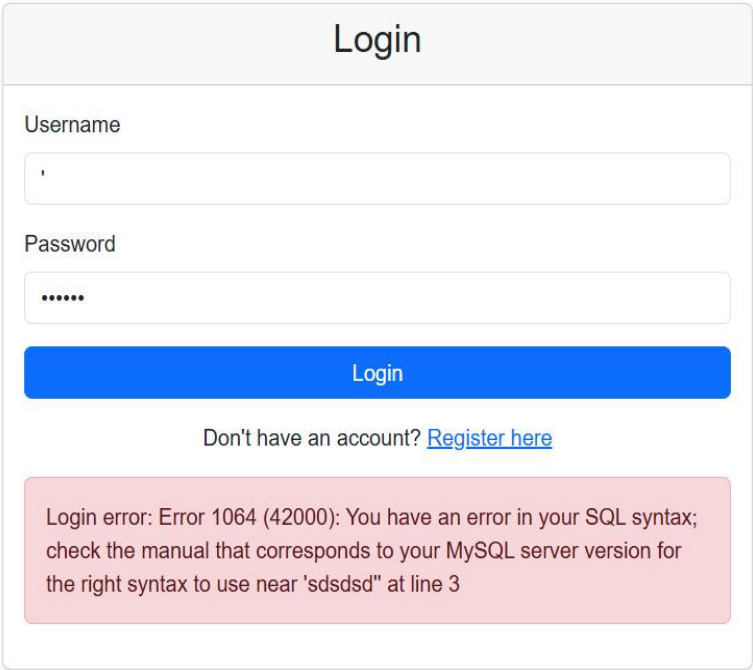
Membocorkan informasi teknis mengenai struktur database dan versi perangkat lunak (*Information Disclosure*) yang memudahkan penyerang menyusun serangan lanjutan.

### e. Nilai Risiko

| | |
|---|---|
| CVSS String | : **AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H** |
| CVSS Base Score | : **10** |
| Rating | : **Critical** |

### f. Langkah-langkah

1. Masuk ke halaman https://jobportal.vulnapp.id/login
2. Masukkan karakter petik tunggal (') atau payload script pada kolom input



3. Sistem merespon dengan pesan error teknis: "*Error 1064 (42000): You have an error in your SQL syntax*"

**g. Rekomendasi**

Nonaktifkan tampilan pesan *error database* secara mendetail di sisi publik dan gunakan penanganan error khusus (*custom error handling*).

**h. Referensi**

http://projects.webappsec.org/w/page/13246914/Application%20Misconfiguration
https://owasp.org/www-community/Improper_Error_Handling
https://cwe.mitre.org/data/definitions/209.html

## 3.3. Time Based Blind SQL Injection - Search Job

**a. Deskripsi**

Kerentanan SQL Injection ditemukan pada *parameter search* di halaman daftar lowongan kerja. Aplikasi tidak melakukan validasi yang cukup terhadap input pengguna, sehingga memungkinkan penyerang untuk menyisipkan perintah SQL. Karena aplikasi tidak menampilkan pesan error secara langsung, penyerang menggunakan teknik *Time-Based* untuk mengekstraksi informasi dengan cara mengukur waktu respon dari server.

**b. URL / Aplikasi**

GET https://jobportal.vulnapp.id/jobs

**c. Status**

**OPEN**

**d. Dampak**

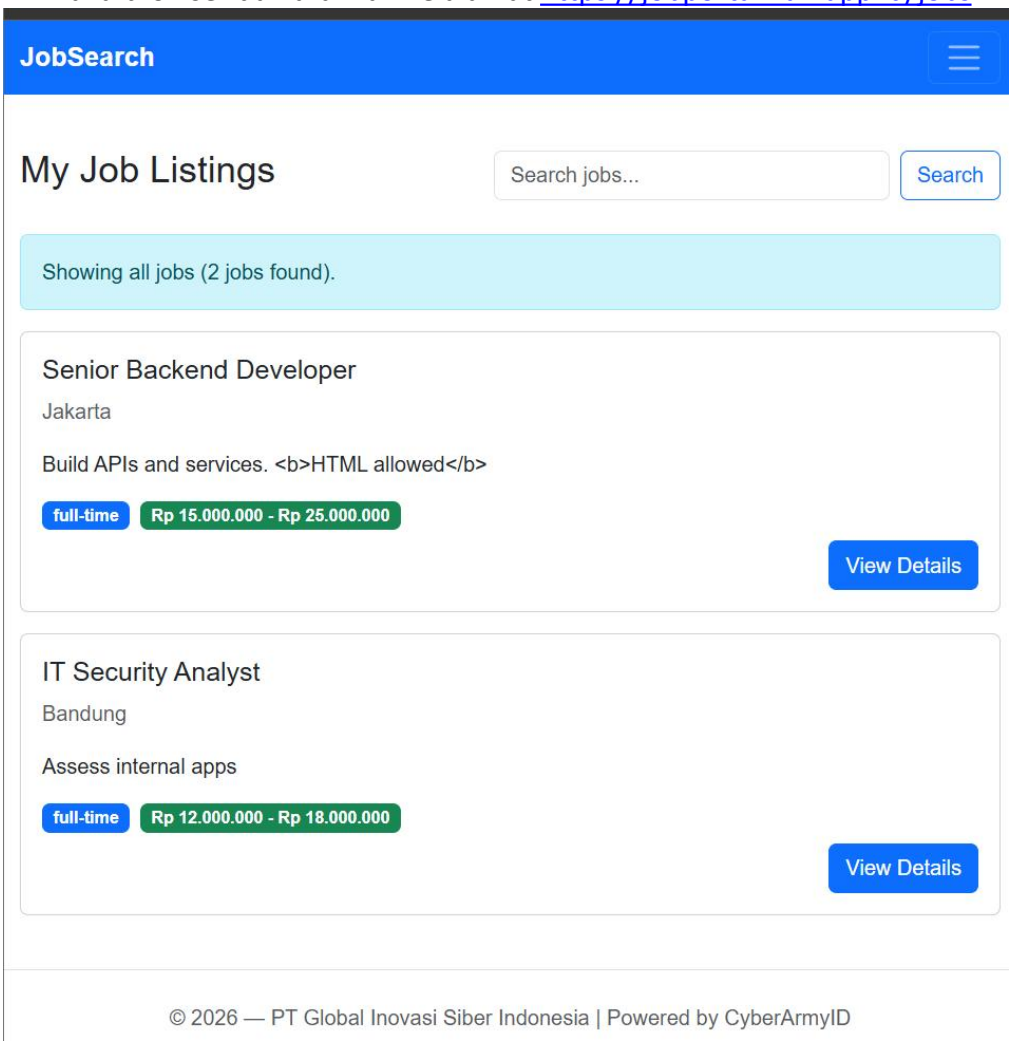
Penyerang dapat melakukan ekstraksi data sensitif dari seluruh tabel database (termasuk tabel pengguna/admin) secara otomatis. Meskipun dilakukan secara perlahan (*blind*), seluruh isi database dapat bocor yang menyebabkan hilangnya kerahasiaan data (*Confidentiality*).

**e. Nilai Risiko**

| | |
|---|---|
| CVSS String | : **AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H** |
| CVSS Base Score | : **10** |
| Rating | : **Critical** |

**f. Langkah-langkah**

1. Buka browser dan arahkan ke alamat https://jobportal.vulnapp.id/jobs




2. Nyalakan fitur *Intercept* pada Helium Core untuk menahan permintaan (*request*) dan balasan (*response*) dari server.

3. Pastikan pengaturan proxy pada browser (menggunakan bantuan ekstensi seperti FoxyProxy) sudah diarahkan ke Helium Core Proxy agar data melewati alat tersebut.

4. Pada search bar, masukkan script berikut : **' AND (SELECT 1 FROM (SELECT(SLEEP(5)))a)--**

5. Perhatikan bahwa di dalam HTTP History, Pada tab Response Time dapat dilihat bahwa delay yang diberikan adalah 5000ms

| ID | Host | Method | Path | Query | Extension | Status | Response L | Response Time | Sent At |
|---|---|---|---|---|---|---|---|---|---|
| 110 | jobportal.vulnapp.id | GET | /api/jobs/search | keyword=%27+AND+%... | | 200 | 2335 | 5143 | 17-04-2026 13:56 |

| Response L | Response Time |
|---|---|
| 2335 | 5143 |

6. Perbandingan Response Time saat mencari keyword lain, contoh: search=backend

| Response L | Response Time |
|---|---|
| 411 | 166 |
| 2335 | 5143 |

**g. Rekomendasi**

Gunakan *Prepared Statements* atau *Parameterized Queries* untuk memastikan bahwa input dari pengguna selalu diperlakukan sebagai data, bukan sebagai bagian dari perintah SQL. Selain itu, implementasikan validasi input yang ketat untuk menolak karakter khusus seperti tanda petik tunggal (') atau kata kunci SQL (SLEEP, SELECT, UNION).

**h. Referensi**

https://owasp.org/www-community/attacks/Blind_SQL_Injection

## 3.4. Sensitive Data Exposure

**a. Deskripsi**

Aplikasi mengirimkan seluruh informasi profil pengguna, termasuk password dalam bentuk teks biasa (*plaintext*), melalui *response body* JSON dan header Set-Cookie setelah pengguna melakukan pembaruan profil.

**b. URL / Aplikasi**

POST https://jobportal.vulnapp.id/profile?id=0

**c. Status**

**OPEN**

**d. Dampak**

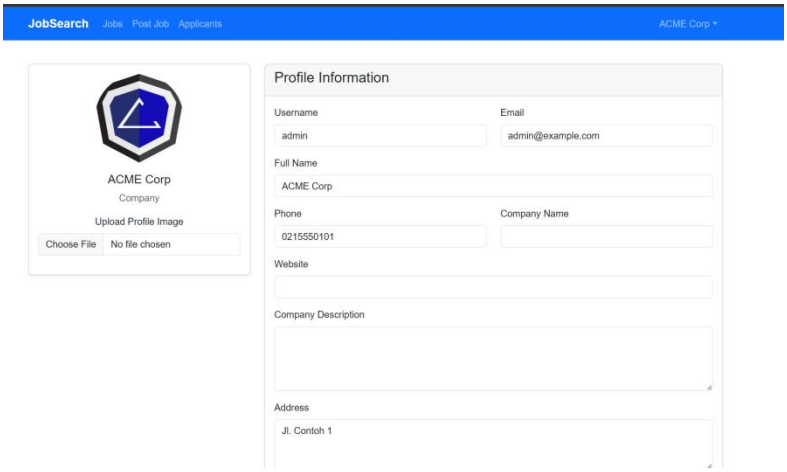
Sangat Tinggi. Jika penyerang berhasil mencuri *cookie* atau melakukan serangan *Man-in-the-Middle* (MitM), mereka dapat langsung mengetahui password pengguna tanpa perlu melakukan proses *cracking* atau *hashing*.

**e. Nilai Risiko**

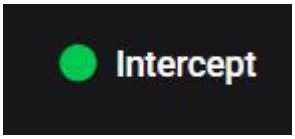
CVSS String : **AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N**
CVSS Base Score : **7.5**
Rating : **Critical**

**f. Langkah-langkah**

1. Login ke website https://jobportal.vulnapp.id
2. Buka Menu Profile

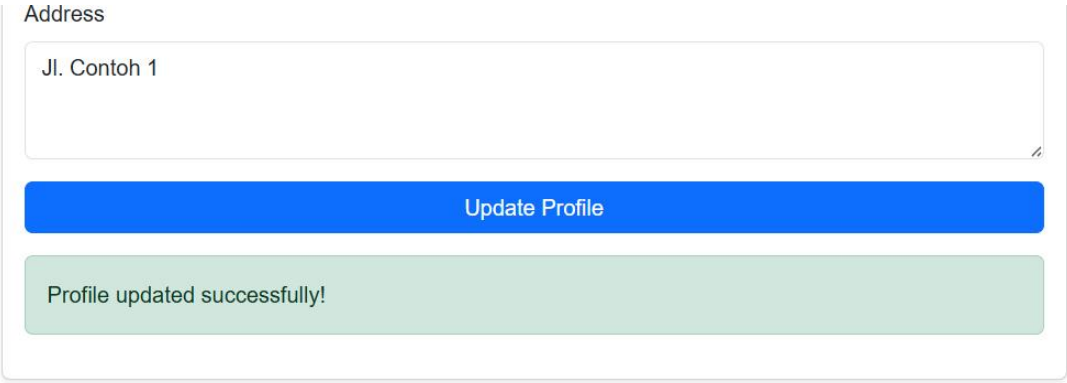



3. Nyalakan fitur Intercept pada Helium Core untuk menahan permintaan (*request*) dan balasan (*response*) dari server.

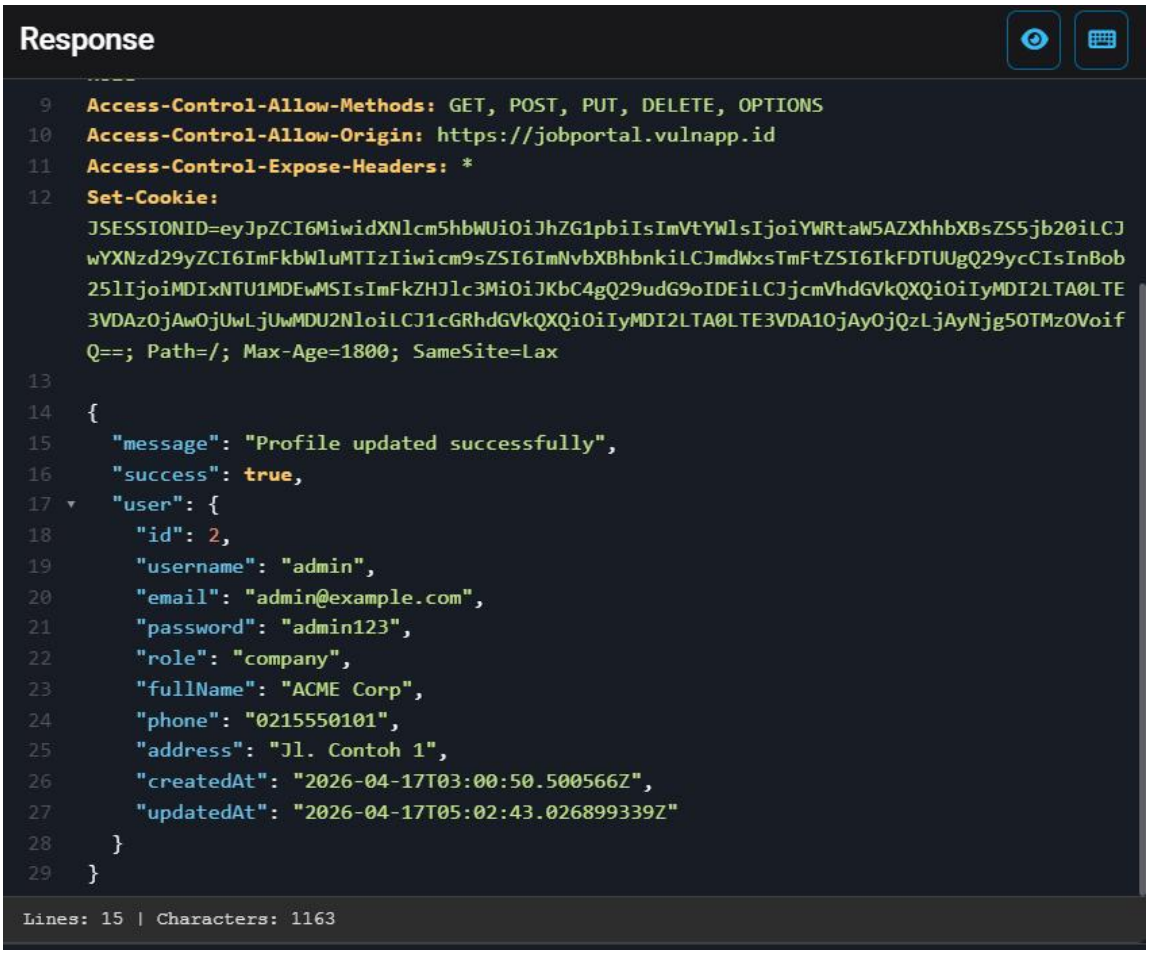



4. Pastikan pengaturan proxy pada browser (menggunakan bantuan ekstensi seperti FoxyProxy) sudah diarahkan ke Helium Core Proxy agar data melewati alat tersebut.

5. Lakukan Klik tombol Update Profile pada aplikasi.




6. Perhatikan bahwa di dalam objek JSON dan header Set-Cookie, terdapat field "password":"admin123"

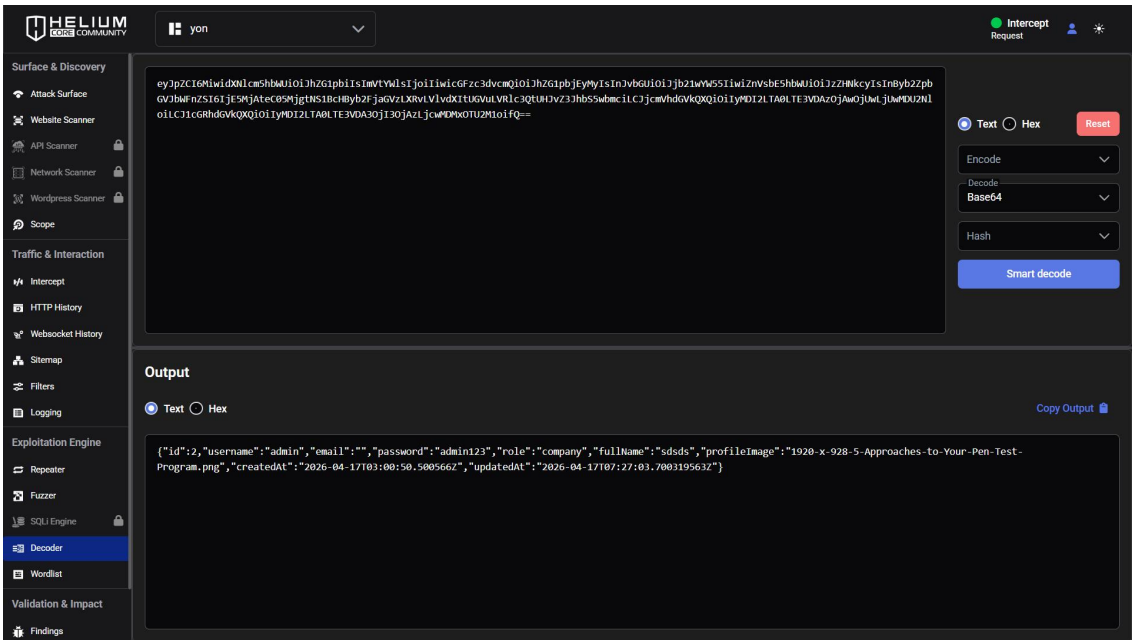


Response

```
Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
Access-Control-Allow-Origin: https://jobportal.vulnapp.id
Access-Control-Expose-Headers: *
Set-Cookie:
JSESSIONID=eyJpZCI6MiwidXNlcm5hbWUiOiJhZG1pbiIsImVtYWlsIjoiYWRtaW5AZXhhbXBsZS5jb20iLCJ
wYXNzd29yZCI6ImFkbWluMTIzIiwicm9sZSI6ImNvbXBhbnkiLCJmdWxsTmFtZSI6IkFDTUUgQ29ycCIsInBob
25lIjoiMDIxNTU1MDEwMSIsImFkZHJlc3MiOiJKbC4gQ29udG9oIDEiLCJjcmVhdGVkQXQiOiIyMDI2LTA0LTE
3VDAzOjAwOjUwLjUwMDU2NloiLCJ1cGRhdGVkQXQiOiIyMDI2LTA0LTE3VDA1OjAyOjQzLjAyNjg5OTMzOVoif
Q==; Path=/; Max-Age=1800; SameSite=Lax

{
  "message": "Profile updated successfully",
  "success": true,
  "user": {
    "id": 2,
    "username": "admin",
    "email": "admin@example.com",
    "password": "admin123",
    "role": "company",
    "fullName": "ACME Corp",
    "phone": "0215550101",
    "address": "Jl. Contoh 1",
    "createdAt": "2026-04-17T03:00:50.500566Z",
    "updatedAt": "2026-04-17T05:02:43.026899339Z"
  }
}
```

Lines: 15 | Characters: 1163

7. Lalu, kita juga bisa melakukan decode kepada kode cookie JSESSIONID= untuk mendapatkan informasi sensitif seperti password




## g. Rekomendasi

Jangan pernah mengirimkan data password kembali ke klien dalam bentuk apapun (Contoh: Plaintext) dan hapus *field password* dari skema respon profil.

## h. Referensi

https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure
https://cwe.mitre.org/data/definitions/312.html

## 3.5. Unrestricted File Upload - Stored Arbitrary File

### a. Deskripsi

Website memiliki kelemahan pada fitur unggah foto profil yang tidak melakukan validasi ekstensi file secara ketat di sisi server. Penyerang dapat mengunggah file dengan ekstensi .php. Meskipun konfigurasi server saat ini mencegah eksekusi langsung (file terunduh/tidak di-*render*), kegagalan dalam membatasi tipe file yang diunggah merupakan celah keamanan serius yang dapat dieksploitasi lebih lanjut jika terjadi perubahan konfigurasi server atau melalui teknik *MIME-sniffing*.

### b. URL / Aplikasi

GET https://jobportal.vulnapp.id/jobs

### c. Status

**OPEN**

### d. Dampak

Meskipun saat ini file .php terunduh, kemampuan untuk mengunggah file arbitrer ke server adalah risiko besar. Jika konfigurasi server berubah sedikit saja, file ini bisa dieksekusi untuk mendapatkan ***Remote Code Execution*** **(RCE)**, yang memberikan kontrol penuh atas server kepada penyerang. Dampak bisnis dari serangan ini adalah pengambilalihan total infrastruktur *server* PT Vulnapp. Penyerang dapat mencuri seluruh *database* utama perusahaan, menghancurkan aset digital, dan menghentikan layanan secara total (*downtime* operasi). Pemulihan dari insiden semacam ini memakan biaya operasional yang sangat mahal.

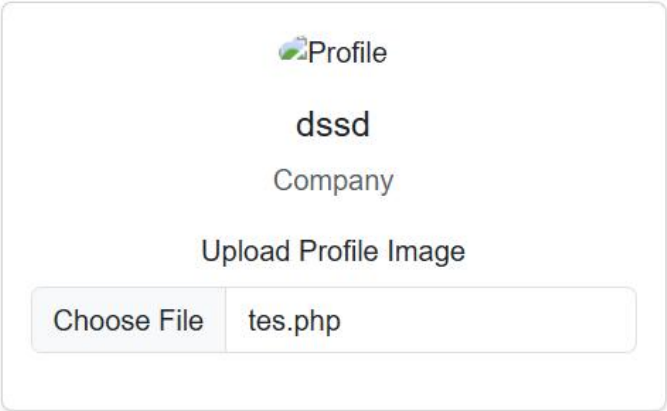
### e. Nilai Risiko

| | |
|---|---|
| CVSS String | : **AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H** |
| CVSS Base Score | : **8.1** |
| Rating | : **High** |

### f. Langkah-langkah

1. Buka menu profil pada https://jobportal.vulnapp.id/profile
2. Nyalakan fitur Intercept pada Helium Core untuk menahan permintaan (*request*) dan balasan (*response*) dari server.
3. Pastikan pengaturan proxy pada browser (menggunakan bantuan ekstensi seperti FoxyProxy) sudah diarahkan ke Helium Core Proxy agar data melewati alat tersebut
4. Buat file .php yang berisikan misal: "<?php phpinfo(); ?>"

5. Lalu pada menu profile klik "*Choose File*" untuk mengganti foto profil yang ada dan pilih file .php yang sudah dibuat




6. Server memberikan respon "200 OK," yang berarti file telah terunggah kedalam server

Raw HTTP Request:

```
POST /api/profile/upload HTTP/1.1
Host: jobportal.vulnapp.id
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryXyz123

------WebKitFormBoundaryXyz123
Content-Disposition: form-data; name="profile_image"; filename="tes.php"
Content-Type: application/x-httpd-php

<?php phpinfo(); ?>
------WebKitFormBoundaryXyz123--"
}
```

Raw HTTP Responses:

```
HTTP/1.1 200 OK
Content-Type: application/json

{
 "status": "success",
 "message": "Profile picture updated successfully",
 "file_path": "/uploads/profile/tes.php"
}
```

Response

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 17 Apr 2026 08:34:27 GMT
Content-Type: application/json
Content-Length: 86
Connection: keep-alive
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With, X-User-Role
Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
Access-Control-Allow-Origin: https://jobportal.vulnapp.id
Access-Control-Expose-Headers: *

{
  "fileName": "tes.php",
  "message": "Profile image uploaded successfully",
  "success": true
}
```

Lines: 14 | Characters: 535

7. Masukan link "https://jobportal.vulnapp.id/uploads/profile/tes.php" ke browser dan secara otomatis browser akan membuka file untuk diunduh kedalam penyimpanan lokal.

esponse

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 17 Apr 2026 08:41:40 GMT
Content-Type: application/octet-stream
Content-Length: 164
Connection: keep-alive

<html><body><h1>PHP File Executed</h1><p>Command execution simulated. In real scenario this would execute system commands.</p><p>Try: ?cmd=whoami</p></body></html>
```

**g. Rekomendasi**

1. Implementasikan *Whitelist* atau perizinan ekstensi file yang hanya mengizinkan .jpg .jpeg dan .png
2. Gunakan pustaka pemrosesan gambar untuk memvalidasi bahwa file yang diunggah benar-benar merupakan file citra (*image validation*).
3. Ubah nama file yang diunggah menjadi format acak (misal: uuid.png) dan simpan di direktori yang tidak memiliki izin eksekusi script.

**h. Referensi**

https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload

## 3.6. Insecure Direct Object Reference (IDOR) - Job Enumeration

### a. Deskripsi

Aplikasi tidak membatasi akses terhadap entitas pekerjaan (*job entities*) berdasarkan otoritas pengguna. Penyerang dapat melakukan enumerasi pada parameter ID di URL (/jobs/[ID]) untuk mengumpulkan data pekerjaan secara massal melalui teknik otomatisasi (Fuzzing).

### b. URL / Aplikasi

GET https://jobportal.vulnapp.id/jobs/1

### c. Status

**OPEN**

### d. Dampak

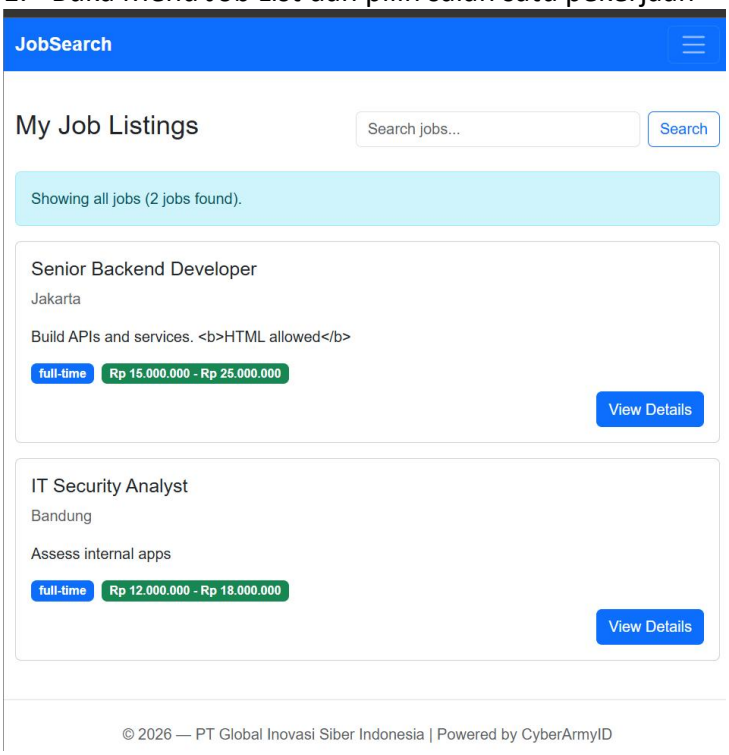
Penyerang dapat melakukan *data scraping* atau pemanenan informasi seluruh lowongan kerja yang ada di database. Jika terdapat pekerjaan yang statusnya masih Draft atau Private, informasi tersebut dapat bocor ke publik.

### e. Nilai Risiko

| | |
|---|---|
| CVSS String | : **AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N** |
| CVSS Base Score | : **7.5** |
| Rating | : **High** |

### f. Langkah-langkah

1. Buka Menu Job List dan pilih salah satu pekerjaan

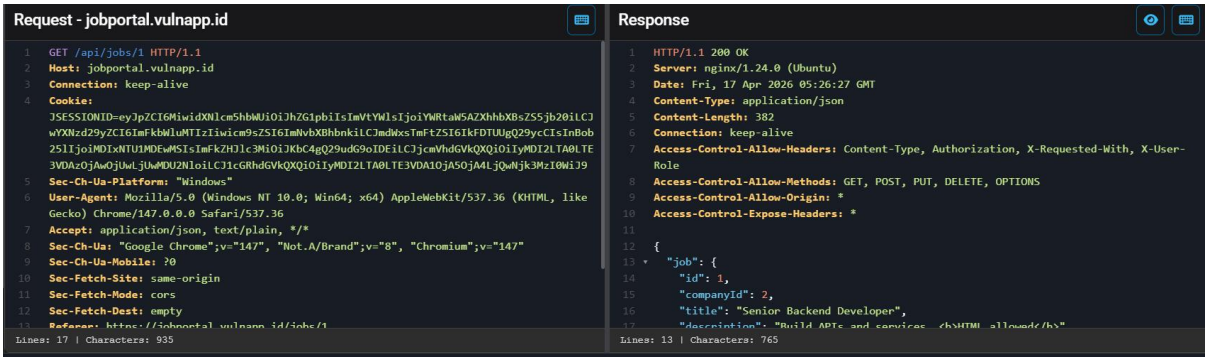


2. Nyalakan fitur **Intercept** pada Helium Core untuk menahan permintaan (*request*) dan balasan (*response*) dari server.

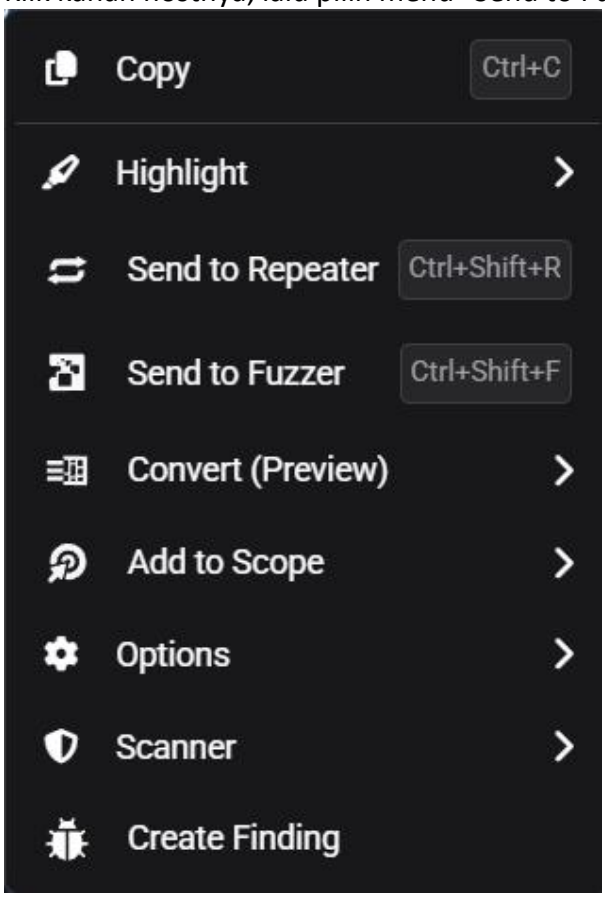
3. Pastikan pengaturan proxy pada browser (menggunakan bantuan ekstensi seperti FoxyProxy) sudah diarahkan ke Helium Core Proxy agar data melewati alat tersebut.

4. Klik tombol View Details dari salah satu pekerjaan

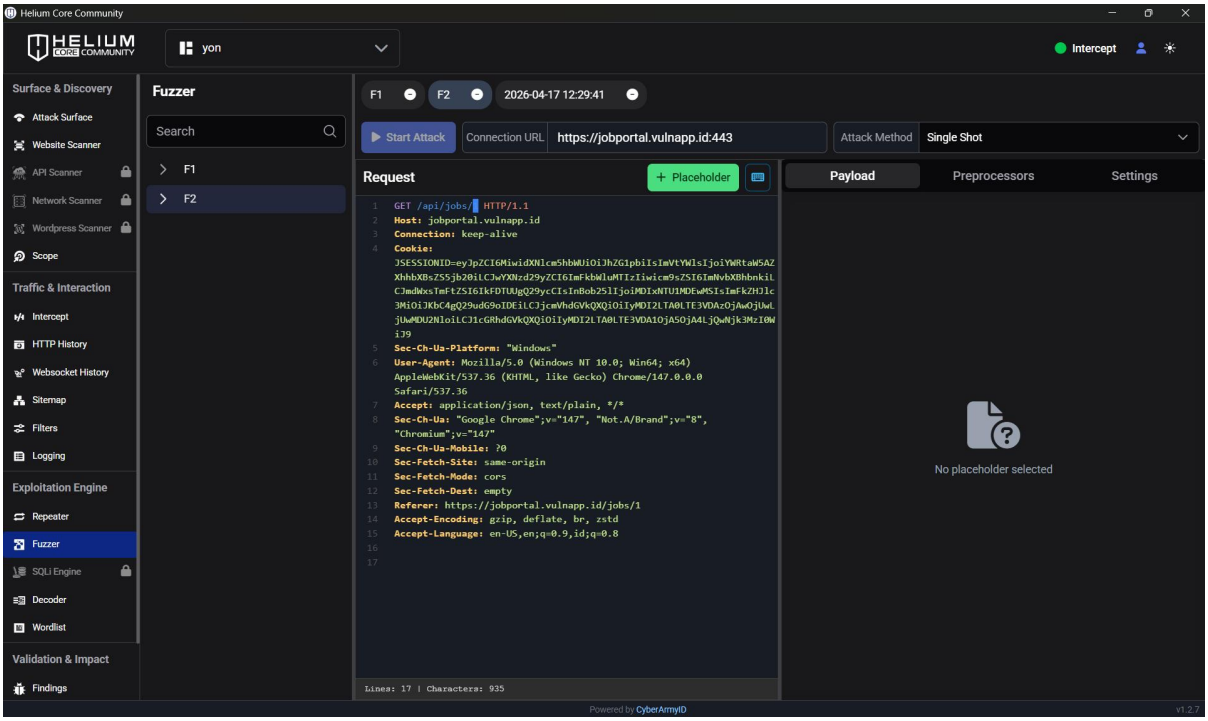
5. Perhatikan bahwa di dalam HTTP History, Request dan Response dari website terdeteksi dan tercatat.



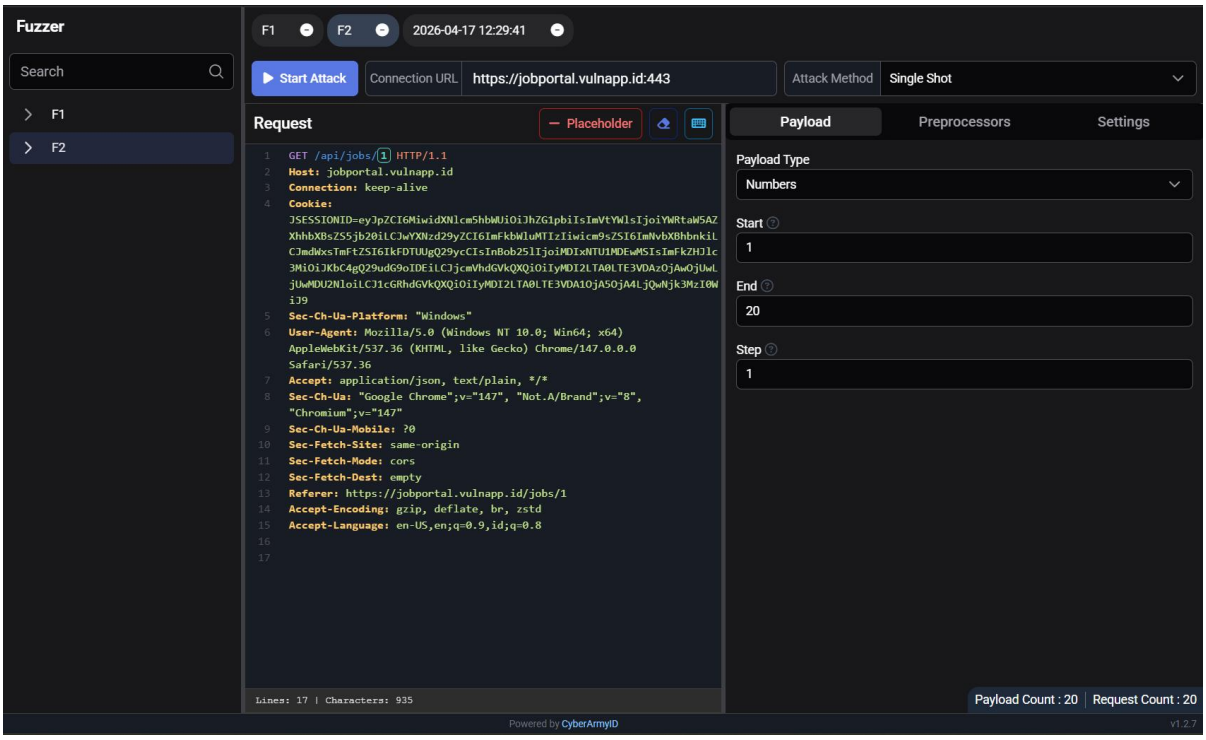

6. Klik kanan hostnya, lalu pilih menu "Send to Fuzzer"



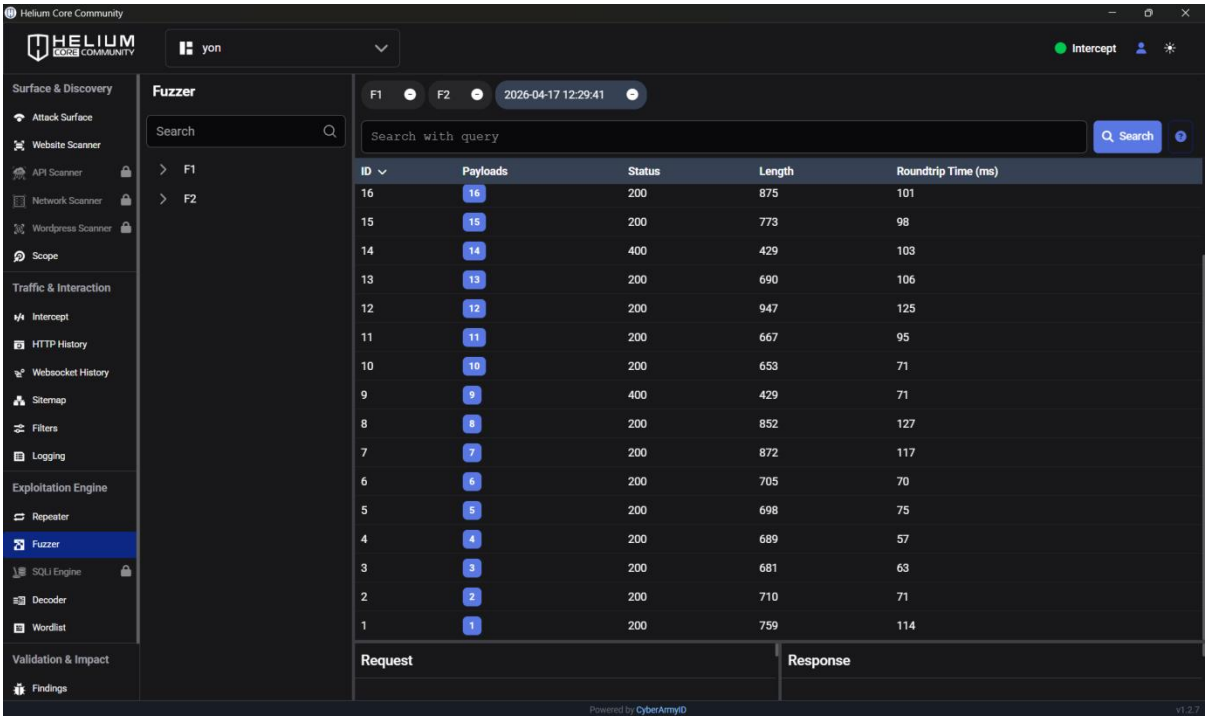
7. Pilih request GET /api/jobs/1, blok atau tandai angka 1nya, lalu klik + Placeholder




8. Masukan Payload type yang merupakan numbers, start dari angka 1 dan end angka 20, step 1.



9. Lalu Klik tombol "Start Attack"
10. Hasil: Ditemukan bahwa 17 dari 20 request menghasilkan status 200 OK dengan ukuran data (*length*) yang berbeda-beda, menandakan setiap ID berisi informasi pekerjaan yang unik dan dapat diakses tanpa validasi lebih lanjut.




## g. Rekomendasi

Gunakan identitas objek yang tidak mudah ditebak seperti **UUID** (contoh: /jobs/a1b2-c3d4...) daripada angka berurutan dan Terapkan pengecekan otorisasi di sisi server untuk memastikan hanya pekerjaan dengan status "Published" yang dapat diakses oleh publik.

## h. Referensi

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References
https://cwe.mitre.org/data/definitions/639.html

## 3.7. Insecure Session Termination (Broken Access Control)

### a. Deskripsi

Ditemukan bahwa aplikasi tidak menghancurkan atau memvalidasi ulang sesi pengguna (*session*) di sisi server setelah pengguna menekan tombol Logout. Meskipun browser telah menghapus cookie secara lokal, token sesi (JSESSIONID) yang lama masih dianggap valid oleh server. Hal ini memungkinkan penyerang yang berhasil mendapatkan akses ke cookie sesi tersebut untuk tetap dapat mengakses akun korban meskipun korban merasa sudah keluar dari aplikasi secara aman.

### b. URL / Aplikasi

POST https://jobportal.vulnapp.id/logout (Target fungsi logout)
GET https://jobportal.vulnapp.id/profile (Target pengujian validasi sesi)

### c. Status

**OPEN**

### d. Dampak

Penyerang dapat melakukan *Session Hijacking*. Jika penyerang berhasil mendapatkan cookie sesi korban (misalnya melalui perangkat publik atau teknik *sniffing*), penyerang tetap memiliki akses penuh ke akun tersebut selamanya atau sampai sesi tersebut kadaluarsa secara alami, meskipun korban sudah melakukan logout berkali-kali.

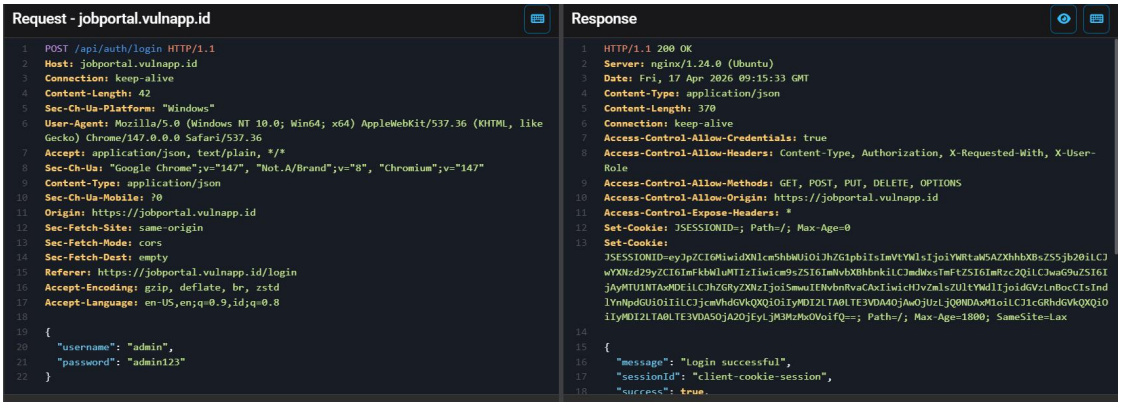
### e. Nilai Risiko

| | |
|---|---|
| CVSS String | **: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N** |
| CVSS Base Score | : **5.3** |
| Rating | : **Medium** |

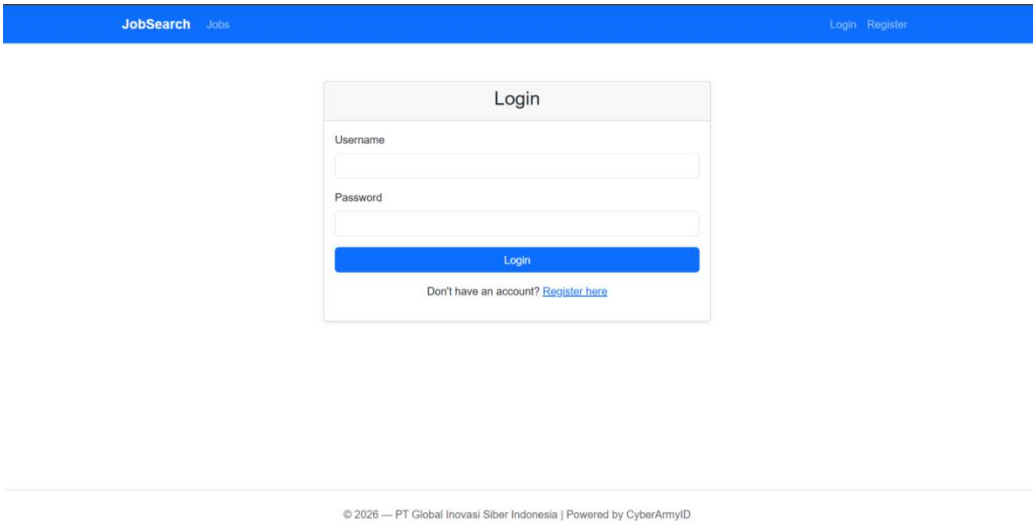
### f. Langkah-langkah

1. Lakukan login pada https://jobportal.vulnapp.id/
2. Nyalakan fitur Intercept pada Helium Core untuk menahan permintaan (*request*) dan balasan (*response*) dari server.
3. Pastikan pengaturan proxy pada browser (menggunakan bantuan ekstensi seperti FoxyProxy) sudah diarahkan ke Helium Core Proxy agar data melewati alat tersebut

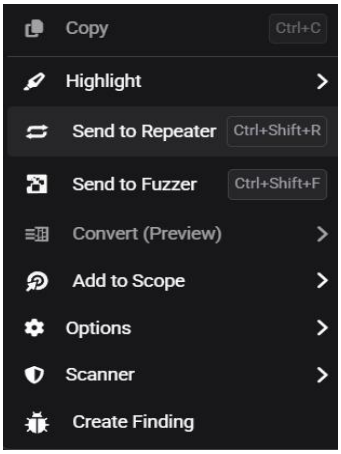
4. cari request ke /profile, lalu catat/salin nilai JSESSIONID yang ada di Header Request



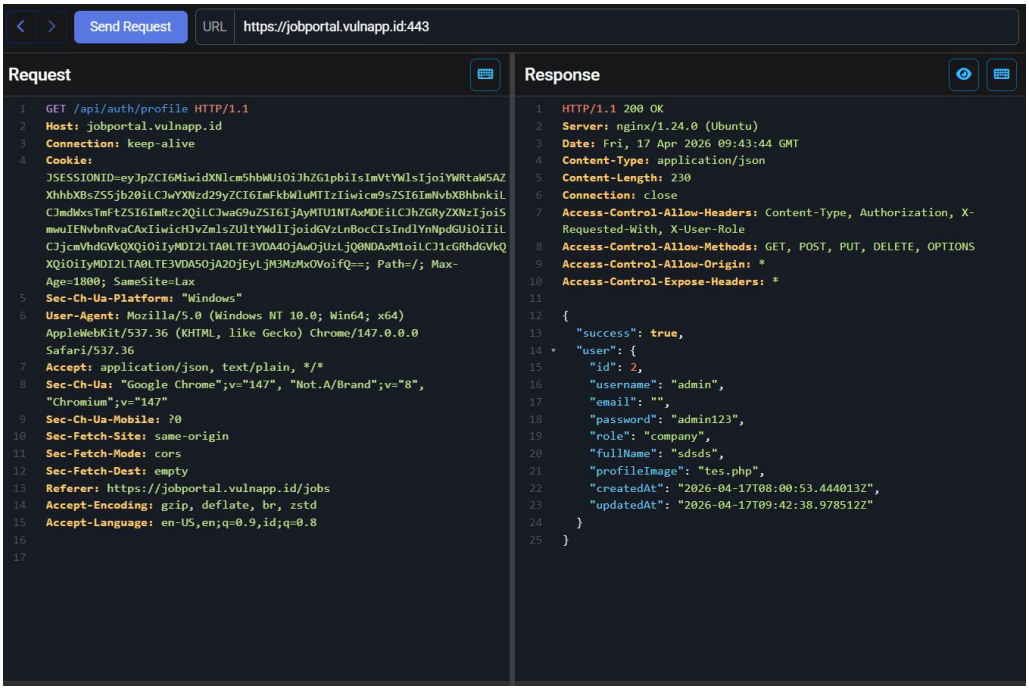

5. Di browser, klik tombol logout




6. Kembali ke Helium Core bagian HTTP History, klik kanan bagian /api/auth/profile dan pilih “Send to repeater”



7. Tempelkan JSESSIONID yang sudah disalin sebelumnya, lalu klik “Send Request”




Dapat dilihat bahwa response server masih memberikan kode 200 OK yang berarti sesi tersebut masih berjalan di server

### g. Rekomendasi

1. Pastikan fungsi logout memicu perintah session.invalidate() (pada Java) atau perintah serupa untuk menghapus data sesi di memori server.
2. Setel waktu kadaluarsa sesi (*Session Timeout*) yang singkat untuk mengurangi jendela waktu eksploitasi.
3. Kirimkan header Set-Cookie dengan tanggal kadaluarsa di masa lalu untuk memastikan browser juga menghapus cookie tersebut secara fisik.

### h. Referensi

https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

## 3.8. Weak Password Policy

### a. Deskripsi

Kerentanan ini terjadi karena aplikasi tidak menerapkan kebijakan kompleksitas password yang ketat di server. Sistem mengizinkan pengguna untuk menggunakan password yang sangat sederhana, pendek, atau mudah ditebak. Tanpa adanya aturan minimal panjang karakter, penggunaan kombinasi angka, huruf besar/kecil, dan karakter spesial, akun pengguna menjadi sangat rentan terhadap serangan otomatis.

### b. URL / Aplikasi

POST https://jobportal.vulnapp.id/register

### c. Status

**OPEN**

### d. Dampak

Penyerang dapat dengan mudah melakukan serangan Brute Force atau Dictionary Attack untuk menebak password pengguna. Jika banyak pengguna menggunakan password lemah (seperti 123, password, atau qwerty), penyerang dapat mengambil alih banyak akun dalam waktu singkat (Mass Account Takeover).

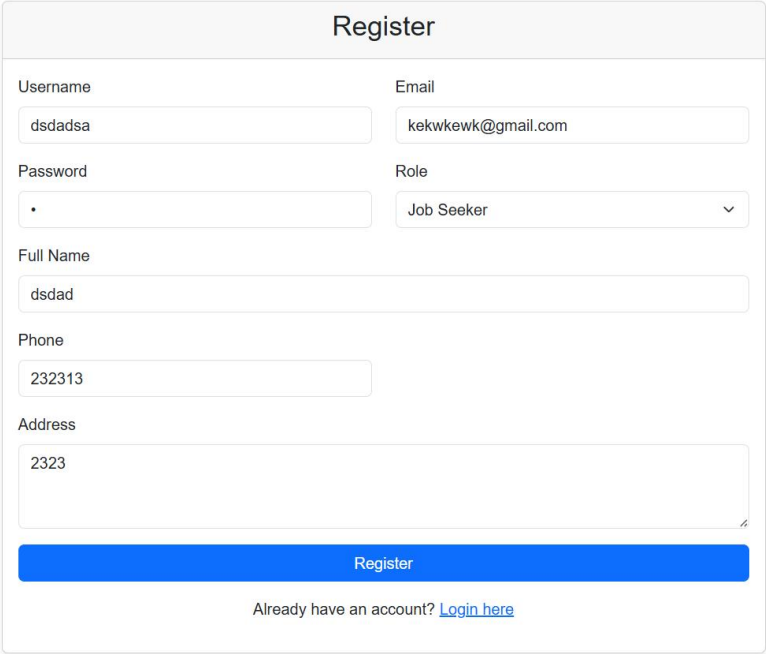
### e. Nilai Risiko

| | |
|---|---|
| CVSS String | **: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N** |
| CVSS Base Score | : **5.3** |
| Rating | : **Medium** |

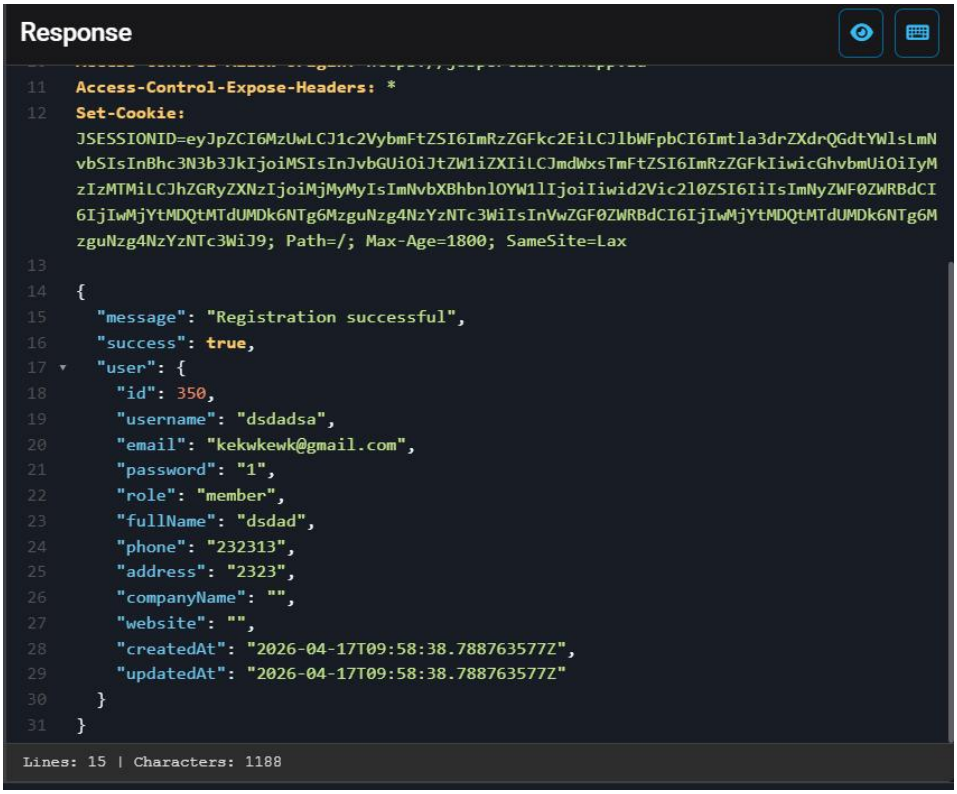
### f. Langkah-langkah

1. Lakukan login pada https://jobportal.vulnapp.id/
2. Klik “Register Here”

3. Masukkan password baru yang sangat lemah, misalnya hanya angka 1 atau kata admin




4. Klik tombol “Register”
5. Dapat dilihat bahwa Response dari server memberikan informasi jika registrasi berhasil



**g. Rekomendasi**

1. Implementasikan kebijakan password yang kuat (minimal 8-12 karakter).
2. Wajibkan penggunaan kombinasi huruf besar, huruf kecil, angka, dan simbol
3. Tambahkan pengecekan di sisi server agar password tidak boleh mengandung username atau kata kata umum yang ada di kamus (*Common Passwords)*
4. Berikan indikator kekuatan password atau *Password strength Meter* pada tampilan UI untuk mengedukasi pengguna

**h. Referensi**

https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

## 3.9. Missing Security Headers (CSP & X-Frame-Options)

### a. Deskripsi

Server tidak mengonfigurasi header *Content-Security-Policy* (CSP), yang berfungsi sebagai lapisan keamanan tambahan.

### b. URL / Aplikasi

POST https://jobportal.vulnapp.id/

### c. Status

**OPEN**

### d. Dampak

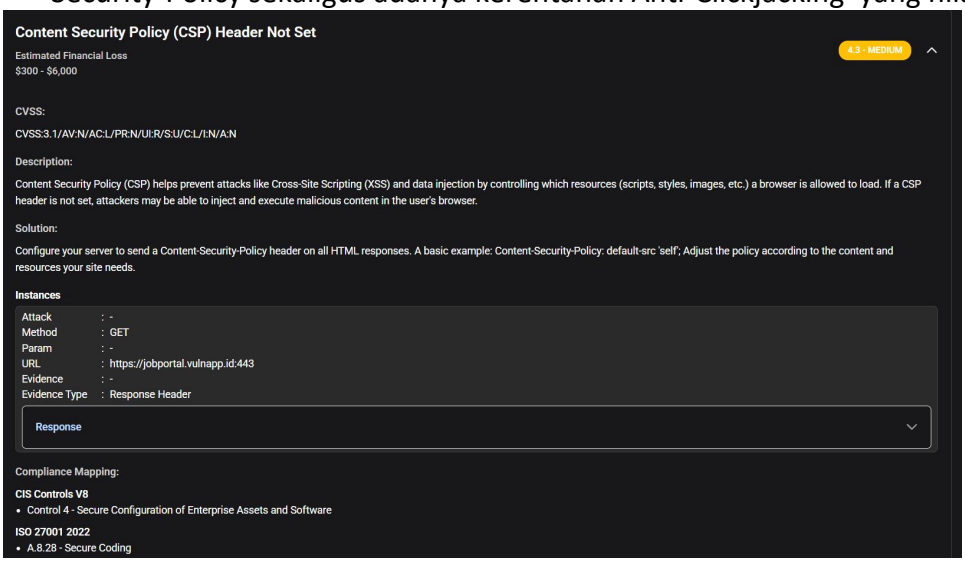
Kombinasi ketiadaan kedua header ini sangat berbahaya. Penyerang dapat melakukan manipulasi tampilan (*UI Redressing*) untuk mencuri klik pengguna atau menyisipkan *script* jahat yang dapat mencuri data sesi pengguna. Hal ini menurunkan tingkat kepercayaan dan keamanan pengguna saat berinteraksi dengan platform.

### e. Nilai Risiko

| | |
|---|---|
| CVSS String | : **AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N** |
| CVSS Base Score | : **4.3** |
| Rating | : **Medium** |

### f. Langkah-langkah

1. Lakukan pemeriksaan pada *Response Header* aplikasi menggunakan fitur website scanner pada aplikasi Helium Core Community
2. Hasil dari scan memberi tahu bahwa tidak ditemukan header Content-Security-Policy sekaligus adanya kerentanan Anti-Clickjacking yang hilang



**Missing Anti-clickjacking Header**

5.4 - MEDIUM

Estimated Financial Loss
$300 - $6,000

CVSS:

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Description:

The response does not include the X-Frame-Options or Content-Security-Policy 'frame-ancestors' directive. Without these, your site may be vulnerable to clickjacking attacks.

Solution:

Set either the X-Frame-Options header (e.g., SAMEORIGIN or DENY), or use the CSP 'frame-ancestors' directive to control who can embed your pages in a frame.

**Instances**

| | |
|---|---|
| Attack | : - |
| Method | : GET |
| Param | : x-frame-options |
| URL | : https://jobportal.vulnapp.id:443 |
| Evidence | : - |
| Evidence Type | : Response Header |

Response

Compliance Mapping:

**CIS Controls V8**

- Control 4 - Secure Configuration of Enterprise Assets and Software

**ISO 27001 2022**

- A.8.28 - Secure Coding

3. Intercept Request ke domain https://jobportal.vulnapp.id lalu periksa tab *Response Headers*

**Response**

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 17 Apr 2026 08:02:29 GMT
Content-Type: text/html
Transfer-Encoding: chunked
Connection: keep-alive
Last-Modified: Wed, 15 Apr 2026 08:55:15 GMT
Etag: W/"69df5273-2b2"
Content-Encoding: gzip

<!doctype html>
<html lang="en">
  <head>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width,initial-scale=1">
    <link rel="icon" href="/cda.svg">
    <title>JobSearch - Vulnerable Training App</title>
      <script defer="defer" src="/js/chunk-vendors.28e7c2cc.js">
      </script>
      <script defer="defer" src="/js/app.fff7f756.js">
      </script>
      <link href="/css/chunk-vendors.bd40d1d7.css" rel="stylesheet">
      <link href="/css/app.93401538.css" rel="stylesheet">
    </head>
    <body>
```

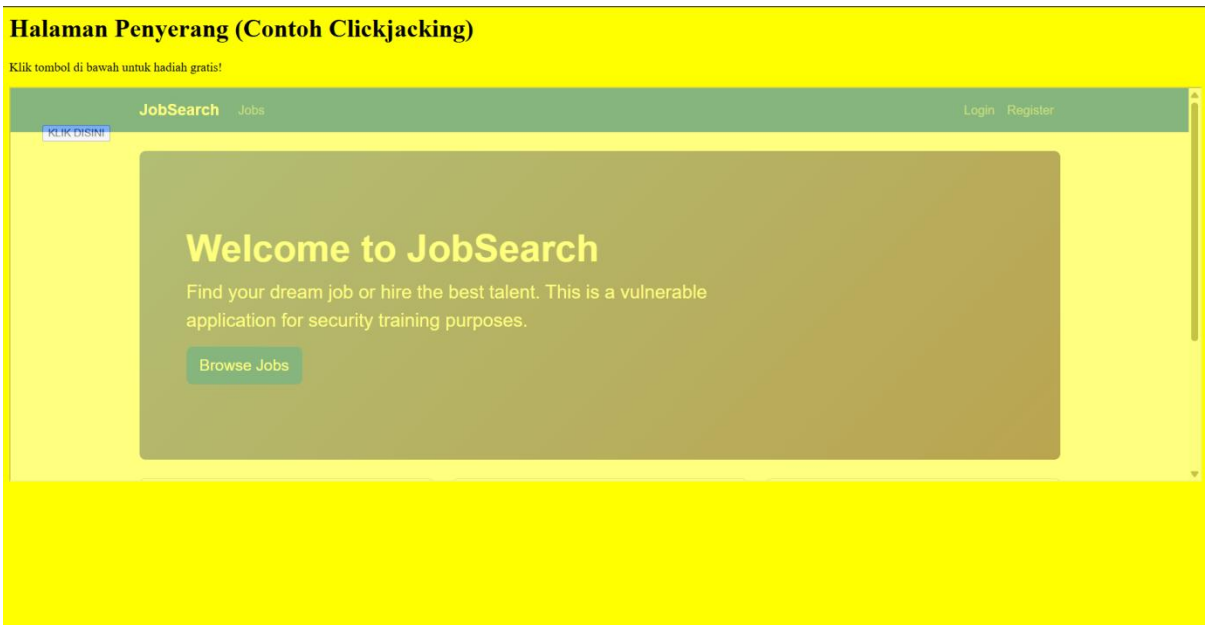
Lines: 11 | Characters: 948

4. Seperti yang dapat dilihat, Content-Security-Policy dan X-Frame-Options tidak ditemukan dalam daftar respon server.

5. Untuk membuktikan dampak dari *clickjacking*, buat file .html seperti ini

```
<html>
 <body style="background-color: yellow;">
  <h1>Halaman Penyerang (Contoh Clickjacking)</h1>
  <p>Klik tombol di bawah untuk hadiah gratis!</p>
  <button style="position: absolute; top: 150px; left: 50px;">KLIK DISINI</button>
  <iframe src="https://jobportal.vulnapp.id/" style="opacity: 0.5; width: 100%; height: 500px;"></iframe>
 </body>
</html>
```

6. Simpan .html dan buka file clickjacking yang sudah dibuat




Terverifikasi bahwa website target berhasil dimuat di dalam frame tersebut.

**g. Rekomendasi**

Konfigurasikan server Nginx (v1.24.0) untuk mengirimkan header keamanan seperti berikut:

1. add_header X-Frame-Options "SAMEORIGIN";
2. add_header Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none';";

**h. Referensi**

https://owasp.org/www-community/attacks/Clickjacking
https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP

## 3.10. Information Disclosure (Nginx Version)

**a. Deskripsi**

Aplikasi membocorkan informasi teknis mengenai versi *web server* dan sistem operasi yang digunakan melalui *response header* Server

**b. URL / Aplikasi**

POST https://jobportal.vulnapp.id/

**c. Status**

**OPEN**

**d. Dampak**

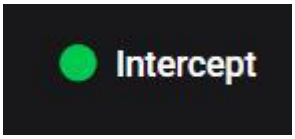
Informasi ini membantu penyerang dalam melakukan *reconnaissance* yang lebih akurat untuk mencari *exploit* atau kerentanan spesifik yang ada pada Nginx versi 1.24.0 atau OS Ubuntu tersebut.

**e. Nilai Risiko**

| | |
|---|---|
| CVSS String | : **AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N** |
| CVSS Base Score | : **3.3** |
| Rating | : **Low** |

**f. Langkah-langkah**

1. Buka URL Target yaitu https://jobportal.vulnapp.id
2. Gunakan Helium Core Community untuk mengecek response halaman tersebut
3. Nyalakan fitur **Intercept** pada Helium Core untuk menahan permintaan (*request*) dan balasan (*response*) dari server.




4. Pastikan pengaturan proxy pada browser (menggunakan bantuan ekstensi seperti FoxyProxy) sudah diarahkan ke Helium Core Proxy agar data melewati alat tersebut.
5. Lakukan refresh atau muat ulang halaman https://jobportal.vulnapp.id

6. Dapat dilihat bahwa response dari intercept yang dapat diliat di page HTTP History menunjukan informasi server version yang digunakan

**Response**

```
1  HTTP/1.1 304 Not Modified
2  Server: nginx/1.24.0 (Ubuntu)
3  Date: Fri, 17 Apr 2026 04:11:28 GMT
4  Connection: keep-alive
5  Last-Modified: Wed, 15 Apr 2026 08:55:15 GMT
6  Etag: "69df5273-2b2"
7
8
```

**g. Rekomendasi**

Konfigurasikan server Nginx untuk menyembunyikan informasi versi dengan mengatur server_tokens off; pada file konfigurasi Nginx.

**h. Referensi**

https://cwe.mitre.org/data/definitions/200.html
https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server